Here are three **detailed SNMP audit-based exam question scenarios**, each covering different security and configuration aspects. These scenarios require students to analyze configurations, identify security risks, and propose solutions.

Scenario 1: Misconfigured SNMP Community and Unauthorized Access

Question:

XYZ Corp has deployed SNMP to monitor its network devices. Their **current SNMPv2c configuration** is as follows:

```
snmp {
    community public {
        authorization read-write;
        clients {
            192.168.1.0/24;
            172.16.0.0/16;
            default allow;
        }
    }
}
```

After a recent security breach, the IT team discovered unauthorized changes in the network configurations. Upon investigation, they found that an external attacker exploited the SNMP settings.

Tasks:

1. Identify and explain at least **three security flaws** in the given SNMP configuration.
2. What **best practices** should be applied to **secure the SNMP configuration**?
3. Modify the given SNMP configuration to follow **best security practices** while still allowing **authorized monitoring** from `192.168.1.0/24`.

Solution:

1. Security Flaws in the Configuration

- **Use of SNMPv2c:** SNMPv2c does **not support encryption** and sends community strings in plaintext, making it vulnerable to **sniffing attacks**.
- **Read-Write Access (`authorization read-write`)**: This allows any authorized client to modify configurations, which could lead to **unauthorized changes or device manipulation**.

- **`default allow;`**: This grants **SNMP access to all clients**, including external attackers, which is a **major security risk**.

2. Best Security Practices for SNMP

✓ **Upgrade to SNMPv3** for **encryption and authentication**.
✓ **Use a strong SNMPv3 username-password with authentication & encryption.**
✓ **Restrict SNMP read-write access** and **grant only read-only permissions** to most users.
✓ **Limit access to trusted IPs** by explicitly defining allowed subnets.

3. Secure SNMP Configuration

```
snmp {
    community secure-monitoring {
        authorization read-only;
        clients {
            default restrict;
            192.168.1.0/24;
        }
    }
}
```

- **Switched to "secure-monitoring" instead of "public"** to avoid well-known default community strings.
- **Restricted all default access (`default restrict;`)** and only allowed `192.168.1.0/24`.
- **Changed to `authorization read-only;`** to prevent configuration changes via SNMP.

Scenario 2: IPv6 Access Control and Malicious SNMP Requests

Question:

A company is using the following SNMP configuration on its network devices:

```
snmp {
    community network-team {
        authorization read-only;
        clients {
            default restrict;
            10.0.0.0/8;
            fe80::1:2:3:4/64;
        }
    }
}
```

Recently, **an unauthorized user was able to retrieve SNMP data** from outside the network, despite the `default restrict;` setting. Further analysis revealed that the attacker used an **IPv6 address** within the allowed range `fe80::1:2:3:4/64`.

Tasks:

1. Explain **why** the attacker was able to access SNMP data despite the `default restrict;` setting.
2. What **security risks** does allowing IPv6 access introduce?
3. Modify the configuration to **block all IPv6 access** while still allowing SNMP access for `10.0.0.0/8`.

Solution:

1. Why the Attacker Could Access SNMP Data

- The attacker used an **IPv6 address inside the allowed range (`fe80::1:2:3:4/64`)**.
- The company **did not apply specific security policies to verify the legitimacy of IPv6 traffic**.
- **Link-local IPv6 addresses (`fe80::/64`)** are automatically assigned and can be spoofed, making them a security risk.

2. Security Risks of Allowing IPv6 Access

🕵 **Lack of IPv6 Monitoring** – Many organizations focus on IPv4 security and ignore IPv6 configurations.
🕵 **Spoofing Risks** – Attackers can **easily generate IPv6 addresses** within allowed ranges.
🕵 **Tunnel Exploits** – Malicious users can **tunnel traffic via IPv6** and bypass IPv4-based firewall rules.

3. Secure SNMP Configuration (Blocking IPv6)

```
snmp {
    community network-team {
        authorization read-only;
        clients {
            default restrict;
            10.0.0.0/8;
            fe80::1:2:3:4/64 restrict;
        }
    }
}
```

✓ **Retained access for** `10.0.0.0/8`.
✓ **Explicitly restricted IPv6 subnet** `fe80::1:2:3:4/64` to block unauthorized use.
✓ **Ensured** `default restrict;` **remains enforced.**

Scenario 3: Implementing Role-Based SNMP Access Control

Question:

A large university has multiple teams that require **different levels of SNMP access** to network devices:

1. **Network Administrators** should have **read-write access** to the `systemMIB` and `interfaceMIB`.
2. **IT Support Staff** should have **read-only access** to `interfaceMIB`.
3. **No other teams should have access to SNMP data.**

The current **SNMP configuration** does not meet these requirements:

```
snmp {
    community admin {
        authorization read-write;
        view all;
    }
    community support {
        authorization read-only;
    }
}
```

Tasks:

1. Identify **two major issues** with this configuration.
2. Modify the SNMP configuration to **implement role-based access control**.

Solution:

1. Issues with the Current Configuration

- **No Access Restrictions**: The `"admin"` and `"support"` communities allow **all SNMP access** without limiting MIBs.
- **Support Team Has Excess Privileges**: `"support"` should only access `interfaceMIB`, but currently, **it has access to everything**.

2. Secure Role-Based SNMP Configuration

```
snmp {
    view admin-view {
        oid systemMIB include;
        oid interfaceMIB include;
    }
    community admin {
        authorization read-write;
        view admin-view;
    }

    view support-view {
        oid interfaceMIB include;
    }
    community support {
        authorization read-only;
        view support-view;
    }
}
```

✓ **Network Admins (`admin` community) have read-write access** to only `systemMIB` and `interfaceMIB`.
✓ **Support Staff (`support` community) have read-only access** to only `interfaceMIB`.
✓ **All other SNMP access is denied by default.**

Conclusion

These three scenarios help students:
✓ Understand **real-world SNMP security challenges**.
✓ Apply **best practices for SNMP security and role-based access control**.
✓ Learn **how attackers exploit misconfigurations** and **how to prevent these risks**.